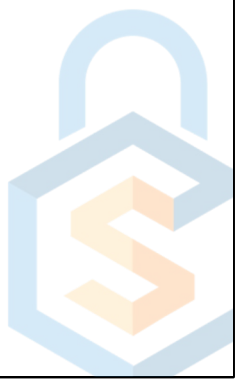
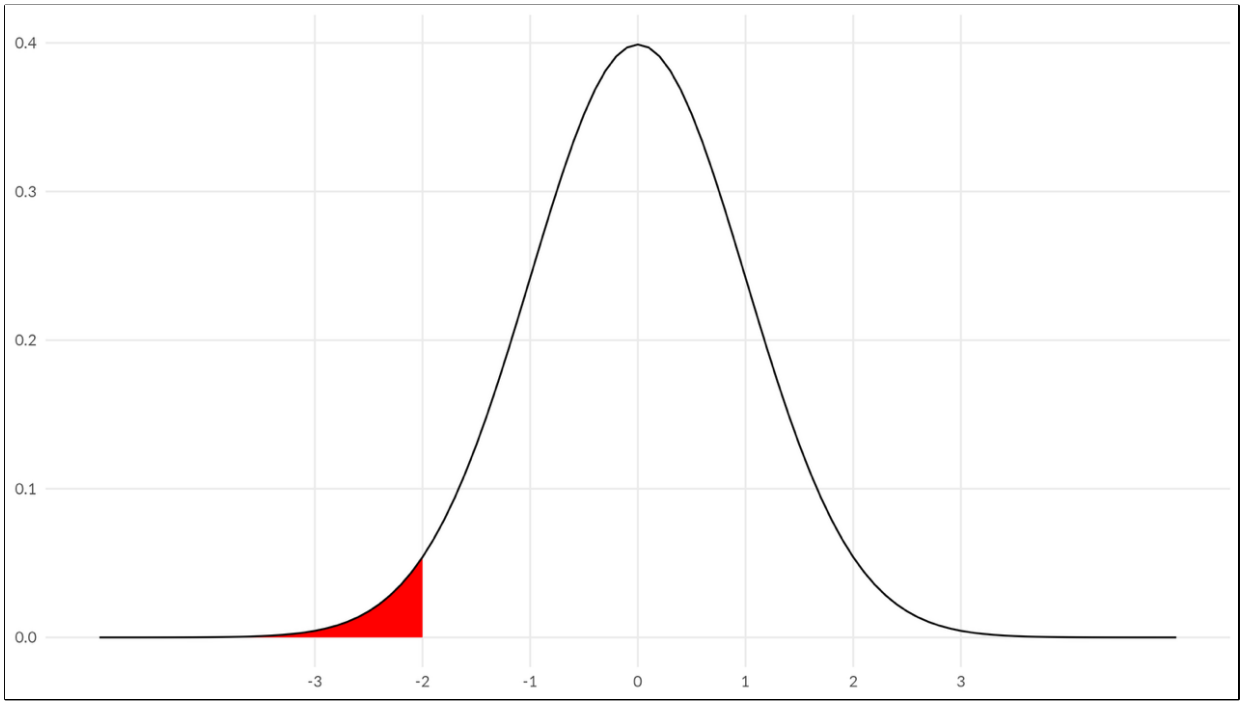
What works in Cybersecurity

John Benninghoff



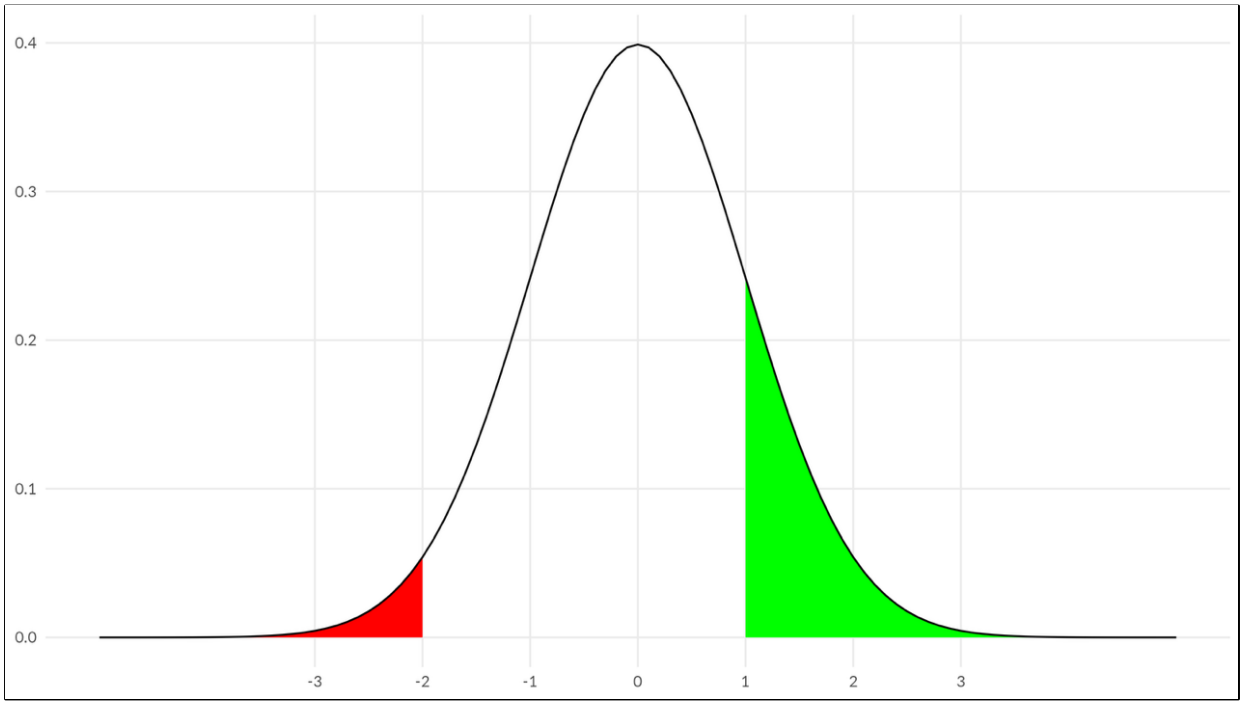
Hi, I'm John Benninghoff, and I'm here to talk about what works in cybersecurity! I'll have a QR code at the end for you to download the slides with notes and links to all the references.

I'd like to start with a story about why we should stop thinking about controls and prevention and instead think about improving performance.



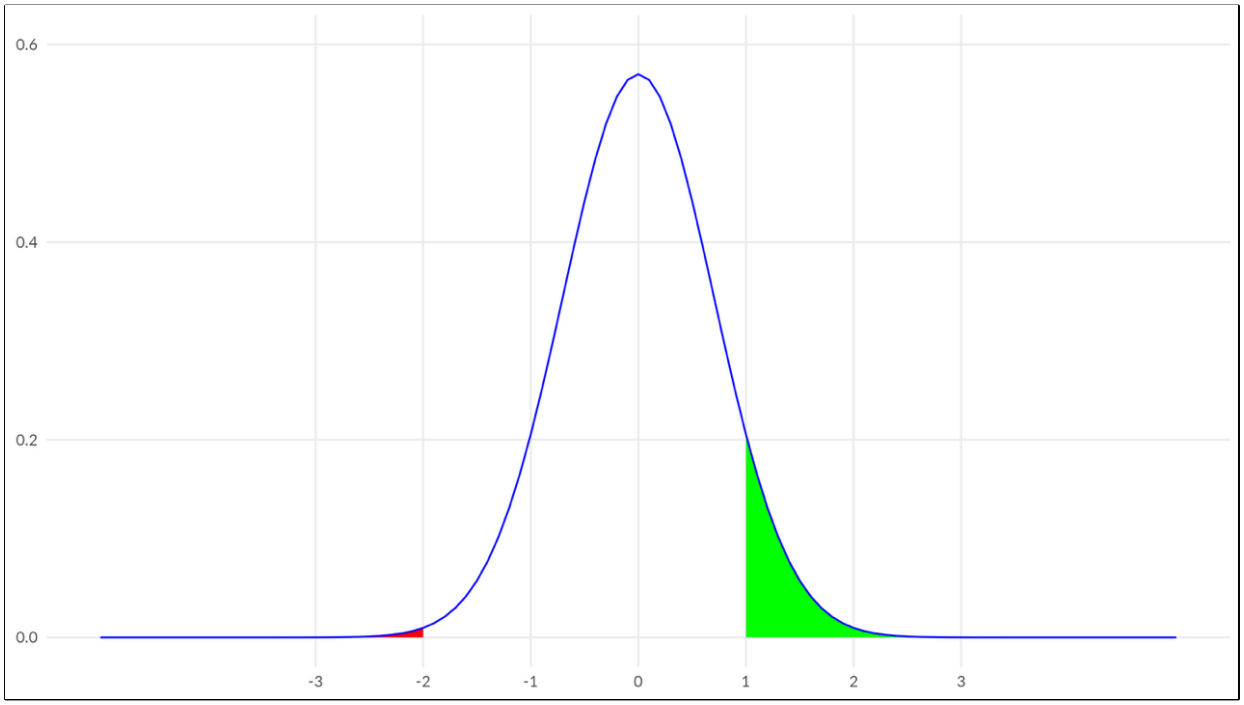
Erik Hollnagel, the scientist who created “Safety-II”, observed that in safety, much like security, we tend to focus on only the bad outcomes. Success happens when we avoid the bad outcomes, shown on this normal curve in red.

https://web.archive.org/web/20260517173257/https://erikhollnagel.com/
R source code for visualizations:
https://jabenninghoff.github.io/security/analysis/constraints.html

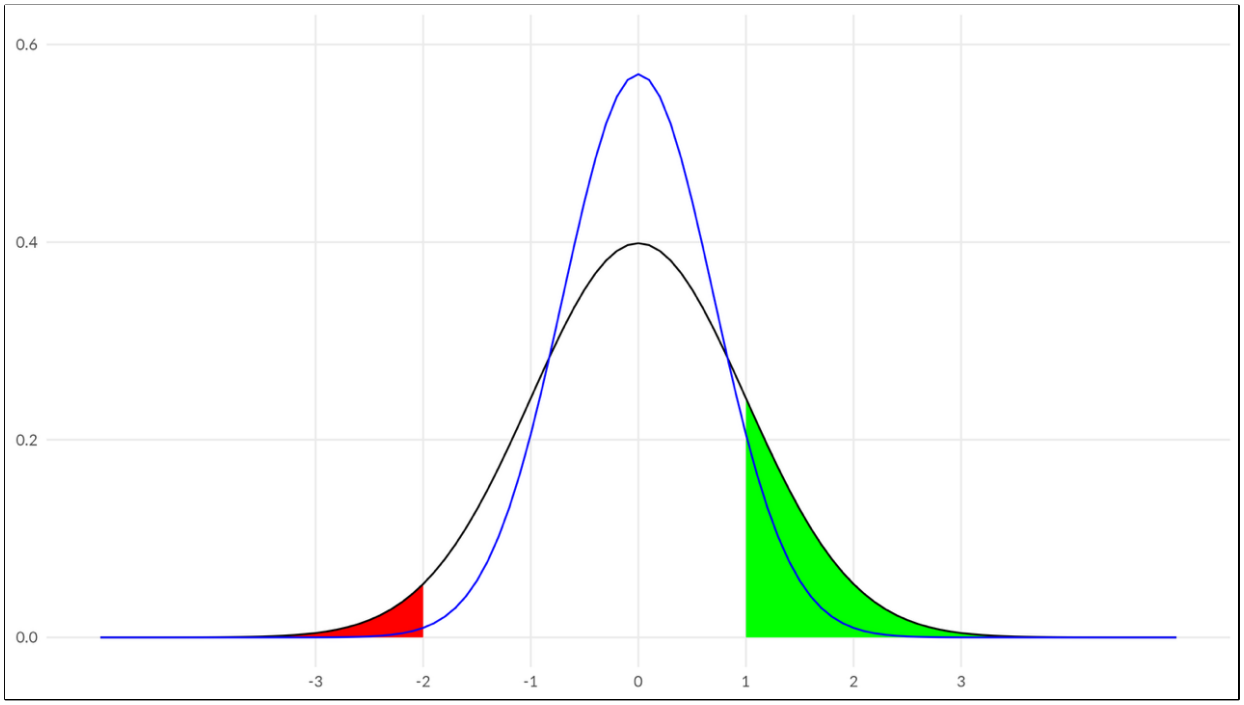


He argued that we can't have a science based on the non-occurrence of bad events – you can't study something that doesn't happen – instead, we must consider and study the whole range of outcomes, including good (green) and bad outcomes, and the "normal" outcomes between.

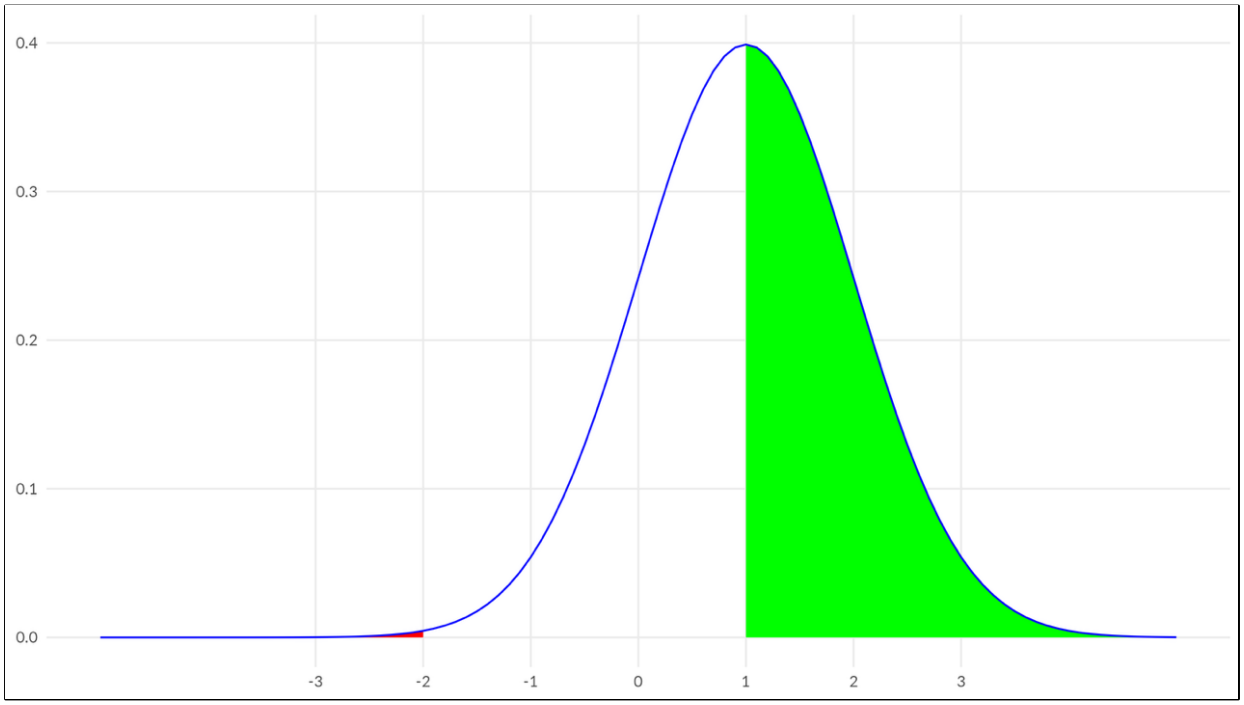
I've observed that there are two ways of reducing bad outcomes.



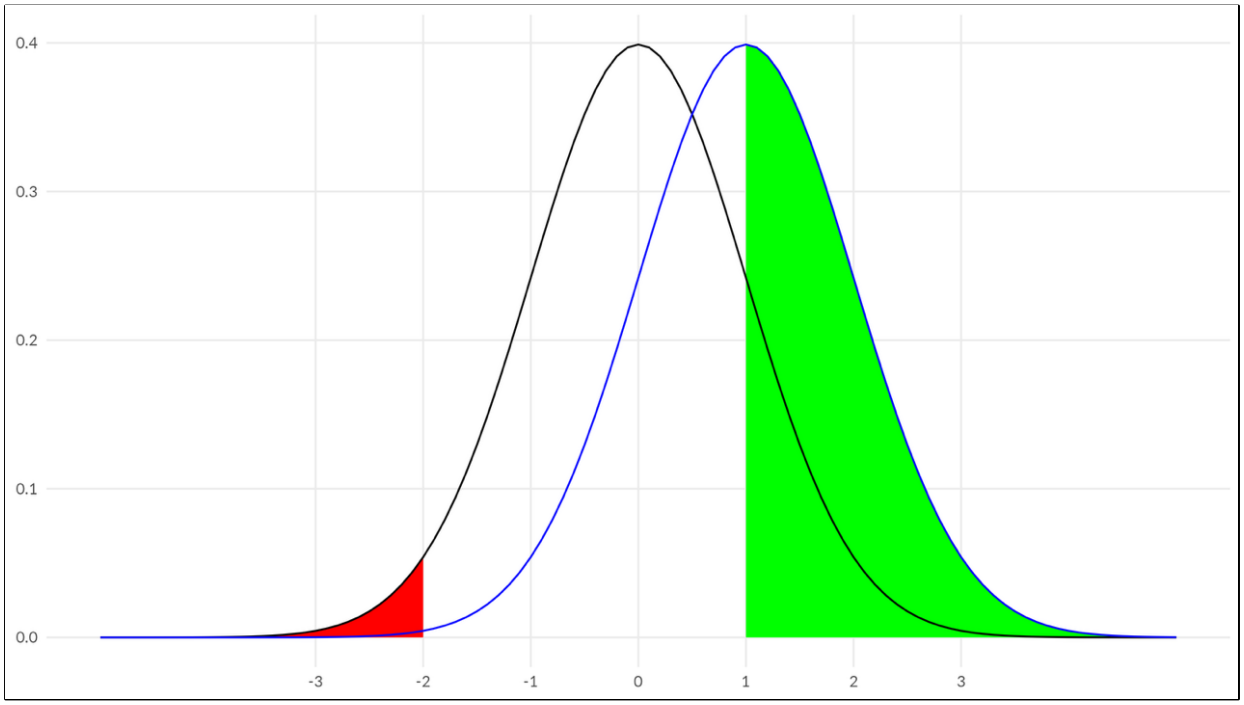
One way is to constrain behavior – introducing policies, controls and procedures that protect against negative outcomes – making the curve narrower.



However, constraints reduce both unexpected negative *and* positive outcomes, shown here. This shows the downside of controls. (my experience - effect of change management on DevOps performance)

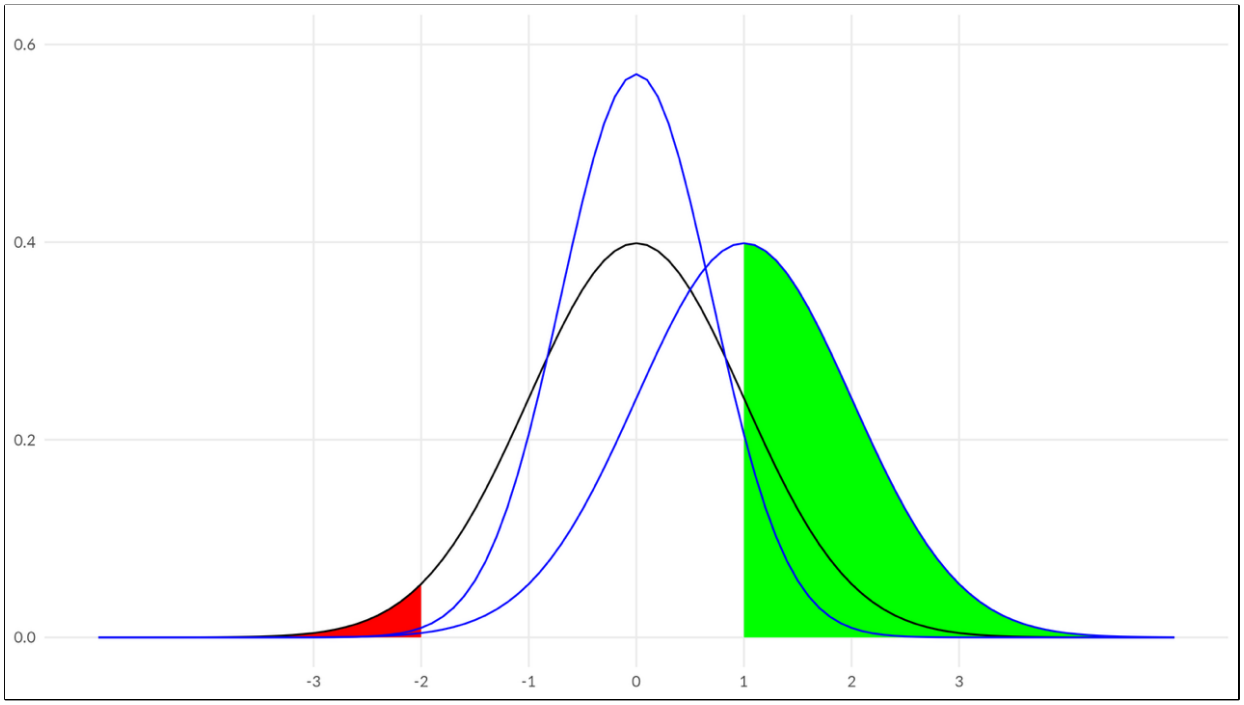


Another, better, way to reduce bad outcomes is by improving performance – shifting the curve to the right.



Focusing on improving performance means that security is no longer an expense, since it both reduces bad outcomes and increases good outcomes. (DORA research)

https://dora.dev/research/
https://www.goodreads.com/en/book/show/35747076



Bringing all three together, this model shows how improving performance is a better strategy – which raises the question, how do we improve security performance?

Part of this is perspective: "I have good security because my home network has never been breached by the Russian or Chinese Governments" vs "We have good security because we successfully defended against an internal red team attack" - preventing occurrence vs performing well when exposed to threats.

What improves performance?

towards an evidence-based cybersecurity practice

For a long time, we couldn't have an evidence-based cybersecurity practice because we didn't have the evidence. Although the first data-based report, the Verizon DBIR, was published in 2008, we only recently have reports with a broad view of breaches, starting with the Cyentia IRIS report in 2020, and reports on cyber claims data from Marsh and Coalition in 2023.

Daniel Woods, who studies the economics of cybersecurity and cyber insurance, has written about what works. From his work and my own, my top 3 are: MFA, cloud, and cyber insurance.

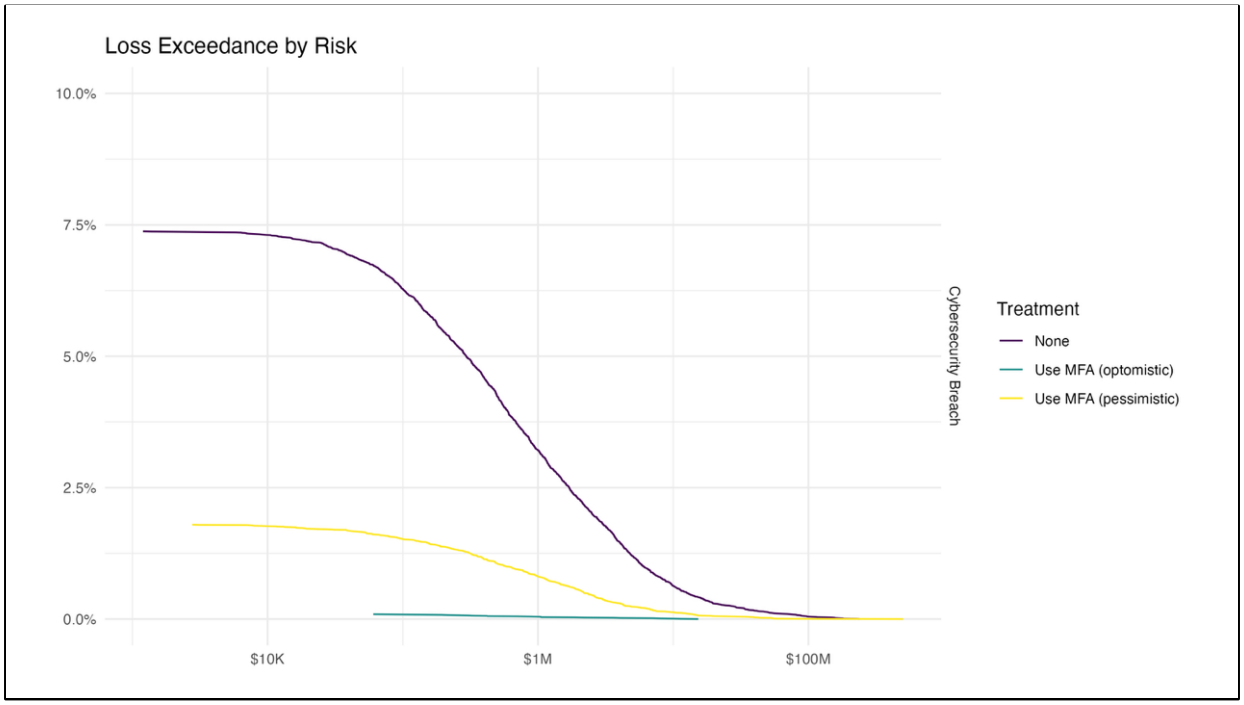
https://www.linkedin.com/posts/are-you-investing-in-the-right-cybersecurity-ugcPost-7440680207281364992-5b8M/
https://www.tandfonline.com/doi/full/10.1080/23738871.2024.2335461

MFA

- "MFA reduces the risk of compromise by 99.22% across the entire population and by 98.56% in cases of leaked credentials" (Microsoft 2023)
- MFA 'prevents 94% of attacks rooted in phishing and 76% of targeted attacks'
  (Google 2019)

MFA, "the closest thing we have in security to a silver bullet." Both studies reviewed internal data of suspicious account activity.

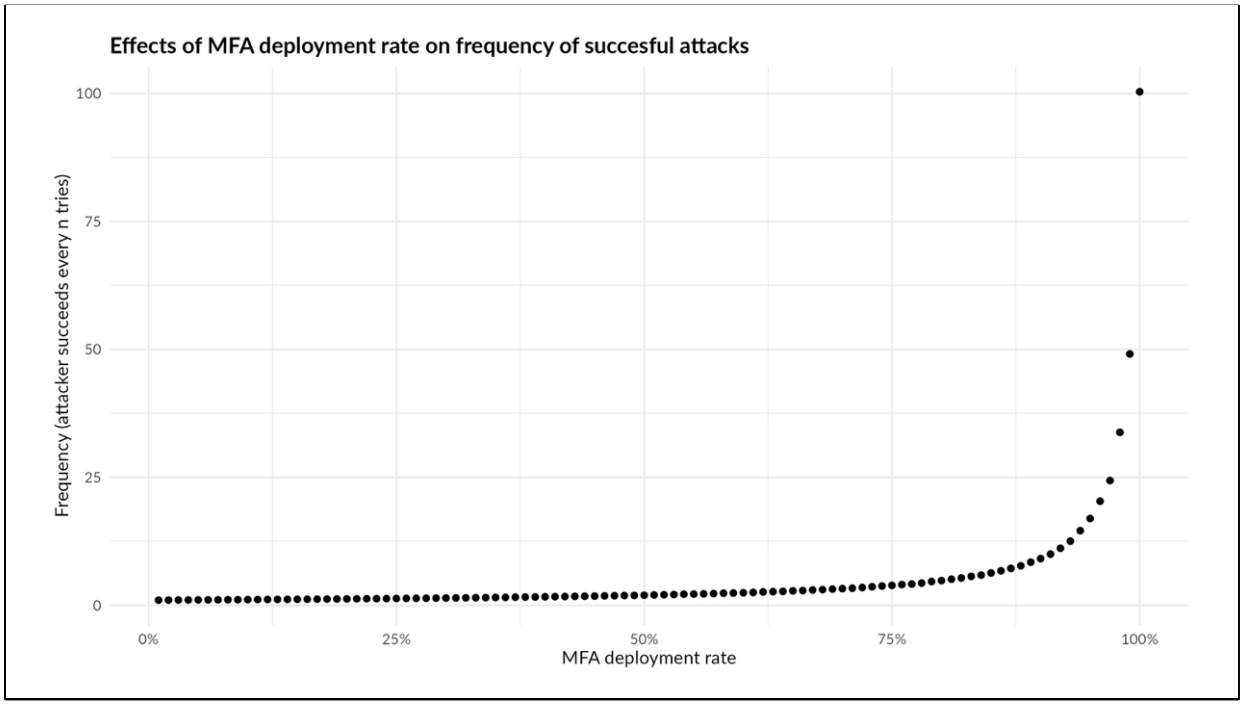
Microsoft 2023: https://arxiv.org/abs/2305.00945
Google 2019: https://dl.acm.org/doi/abs/10.1145/3308558.3313481
https://www.linkedin.com/pulse/what-works-cybersecurity-mfa-daniel-woods-e7mke/



I did an analysis to quantify the reduction in risk for both the optimistic (99%) and pessimistic (76%) reduction in likelihood for using MFA vs baseline, using data from the Cyentia IRIS 2025 Report.

For a generic professional services firm with $5M in revenue, MFA reduces the risk of a loss exceeding $1M from 3% to 0.8% or to nearly 0 (<0.03%). Especially if we believe the optimistic case, this is a HUGE reduction in risk. However, cyber insurance claims analysis doesn't show the same risk reduction for organizations. Why would individuals see a big risk reduction and organizations not? We don't know for sure, but deployment rate is the likely factor.

https://jabenninghoff.github.io/quantrr/example/analysis/mfa.html
https://www.cyentia.com/multi-incident-probabilities/
https://www.cyentia.com/publication/iris2025/
https://www.marsh.com/en/services/cyber-risk/insights/using-cybersecurity-analytics-to-prioritize-cybersecurity-investments.html
https://www.guycarp.com/insights/2024/07/cyber-sleeper-threat-business-email-compromise.html



I modeled the effect of deployment rate on attack success rate using Monte Carlo simulation. It seems obvious after the fact, but the success rate is basically the inverse of the deployment rate: with MFA 50% deployed, an attacker succeeds 50% of the time, 80%/20%, etc.

A 100% deployment rate (every 100 tries) is about twice as effective as a 99% deployment rate (every 50 tries). Organizations should work to get a 100% deployment rate.

https://jabenninghoff.github.io/security/analysis/mfa-deployment.html

Cloud

- On-premise Exchange increases claims by as much as 256% (Coalition 2023)

- Cloud email significantly decreases claims (At-Bay 2003)
  - Microsoft Exchange: 0.189%
  - Microsoft 365: 0.140%
  - Google Workspace: 0.070%

2.56 claims rate for on-premise Exchange for firms >$100M in 2022 (due to unpatched vulnerabilities).

Claims for insured without email security solutions (mid-2018 to 2022), normalized claims frequency. Side note: Mimecast was the best email security solution (0.097%), **not as good as Google.**

https://web.coalitioninc.com/download-2023-cyber-claims-report.html
https://www.at-bay.com/ranking-email-security-solutions/

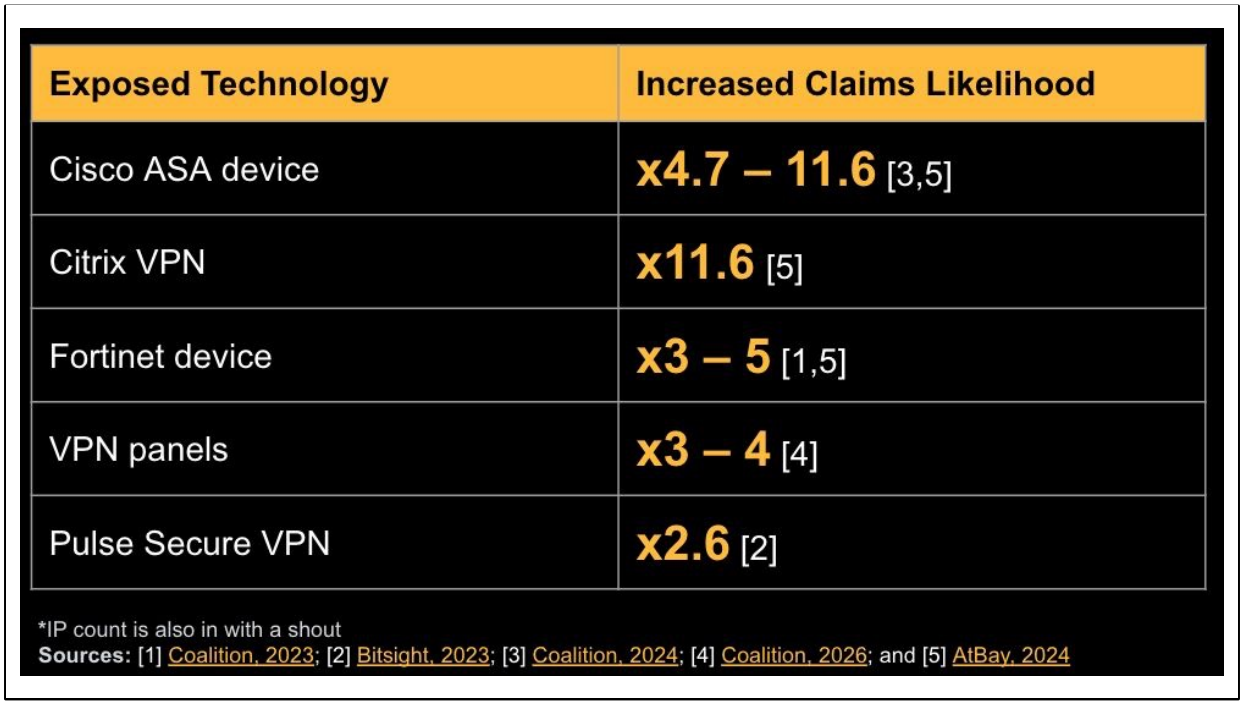
Cyber Insurance

- Cyber breaches are rare, expensive events
- Insurance fits well for rare, expensive events (homeowners, auto, liability, etc.)
- “One number to call"

There’s less direct evidence for this, but cyber insurance is a good strategy, especially for organizations too small to hire dedicated security staff (ie most of them). It helps cover risk, and provides one number to call when things go wrong, even before a claim is filed, the insurer can provide lawyers and incident response, much like they do for other forms of insurance.

What doesn’t work?

So, what doesn’t work? In short, legacy perimeter security devices.



Exposed Technology	Increased Claims Likelihood
Cisco ASA device	**x4.7 – 11.6** [3,5]
Citrix VPN	**x11.6** [5]
Fortinet device	**x3 – 5** [1,5]
VPN panels	**x3 – 4** [4]
Pulse Secure VPN	**x2.6** [2]

*IP count is also in with a shout
Sources: [1] Coalition, 2023; [2] Bitsight, 2023; [3] Coalition, 2024; [4] Coalition, 2026; and [5] AtBay, 2024

Companies with VPNs and other perimeter security devices are much more likely to file a cyber insurance claim. You are safer using the internet (and appropriate controls, like MFA) than an “internal” network! (Thanks again to Daniel Woods!) Normalized claims data. Perimeter security is an attractive target for attackers and more importantly creates a false sense of security. (RDP on the internet? NO! RDP on the internet behind a VPN? YES!)

Source:
https://www.linkedin.com/feed/update/urn:li:activity:7454125124451995648/

Evidence-Free Advice: Hacklore





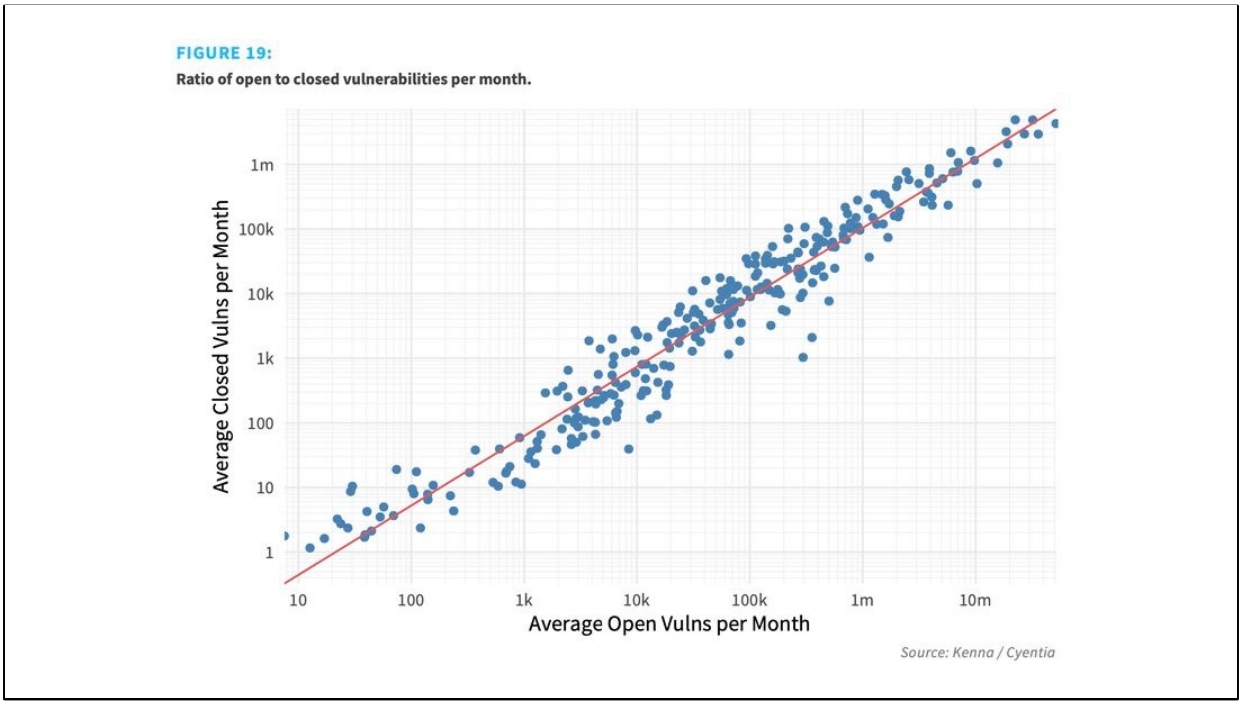


We also have “Hacklore” – security advice that persists despite no evidence that it’s currently a threat. The 3 most common? Don’t use public USB chargers (juice jacking), Public Wi-Fi, or QR codes. (One security presenter said “don’t scan QR codes” right before showing a QR code for his website). These have some basis in reality but are no longer threats.

https://www.hacklore.org
https://commons.wikimedia.org/wiki/File:Condom_USB_de_PortaPow.jpg
https://commons.wikimedia.org/wiki/File:Wifi-solid.svg
https://www.youtube.com/watch?v=dQw4w9WgXcQ

What about patching?

Patching, especially patch cadence is a strong predictor of better security outcomes. However, except perhaps for a few unicorns, most organizations struggle with patching.



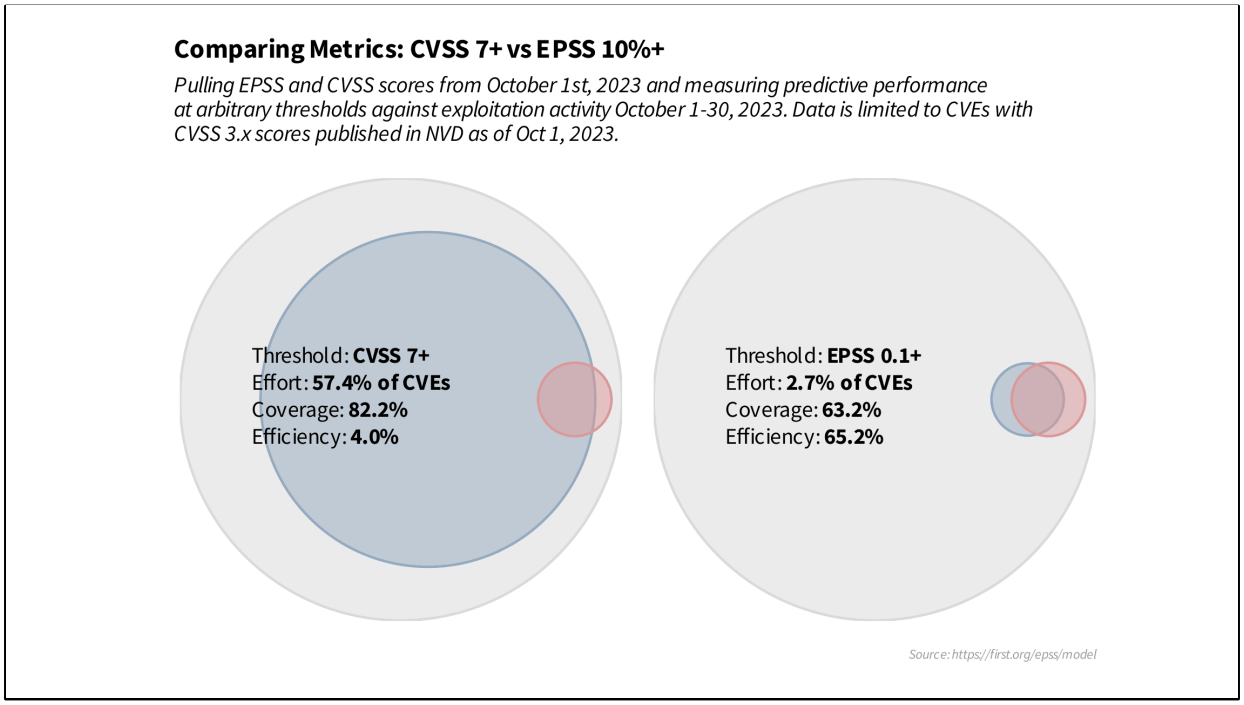
We've had Vulnerability Management since 2001-2002, and yet we still struggle.

In 2019, Cyentia and Kenna found that "A typical organization will have the capacity to remediate about one out of every 10 vulnerabilities in their environment within a given month. That seems to hold true for firms large, small, and anywhere in between." – there are no economies of scale, and the number of open vulns is growing over time.

https://www.cyentia.com/the-hidden-complexity-of-vulnerability-remediation/
2002 papers on VM:
https://doi.org/10.1016/S1353-4858(02)05013-4
https://doi.org/10.1016/S1363-4127(02)00104-8

Prioritize: EPSS + KEV

What's the best approach to prioritizing patches? Consensus is some version of EPSS + KEV.



CVSS isn't very helpful for prioritization. EPSS significantly outperforms CVSS; fewer false positives and false negatives for less effort. However, you can't rely on EPSS alone, since it is only a predictive model and BY DESIGN does not reflect actual exploitation activity. KEV is a reliable curated list of vulns being actively exploited. If you have it, use your own exploitation data. (and this is for an older version of EPSS – EPSSv3. Currently on EPSSv5.)

https://web.archive.org/web/20260723011121/https://www.first.org/epss/model
https://www.first.org/epss/

Software Product Liability

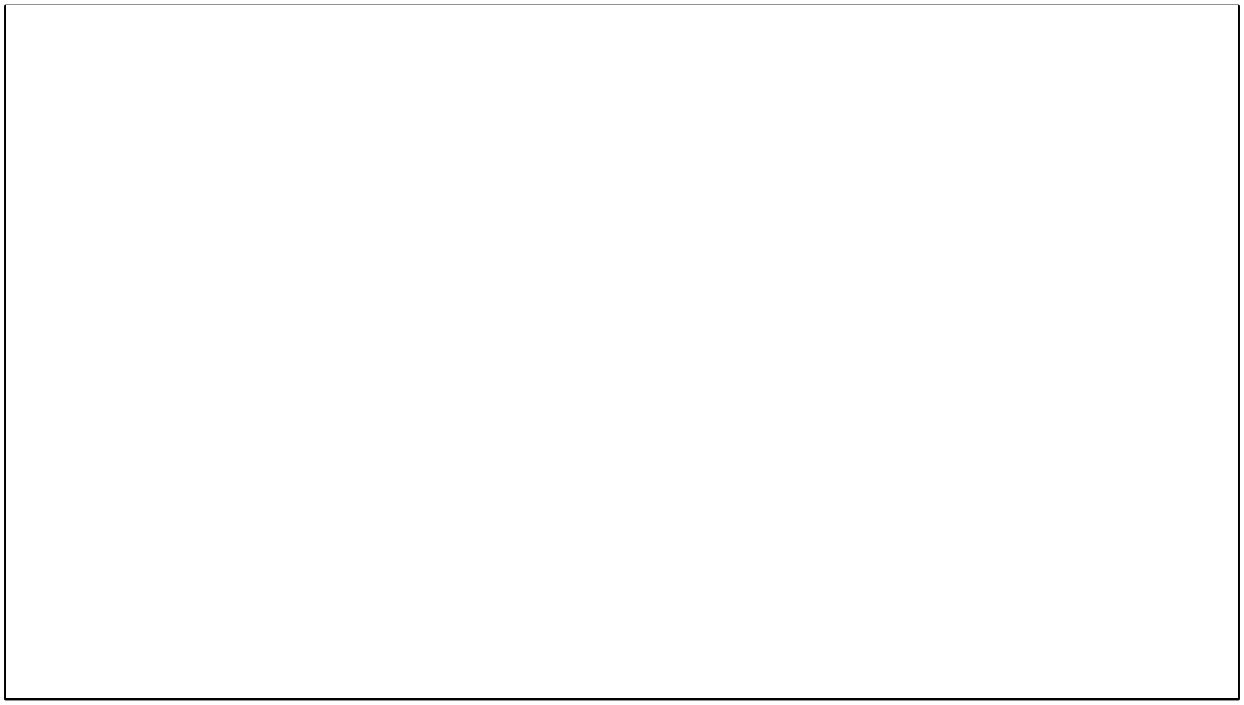




Arguably, we shouldn't need to patch. Consumer product safety, including warning labels and product recalls, is largely driven by manufacturers wanting to protect themselves against lawsuits. We could change laws around software and software licensing to shift greater liability to tech companies. Europe has started to do this through the EU Product Reliability Directive and Cyber Resilience Act.

https://www.routledge.com/Handbook-of-Warnings/Wogalter/p/book/9780805847246
Image:
https://commons.wikimedia.org/wiki/File:16_CFR_§_1205.6_Warning_label_for_reel-type_and_rotary_power_mowers.svg

https://eur-lex.europa.eu/eli/dir/2024/2853/oj/eng
https://www.gibsondunn.com/eu-product-liability-directive-responding-to-software-ai-and-complex-supply-chains/
https://en.wikipedia.org/wiki/Cyber_Resilience_Act
https://commons.wikimedia.org/wiki/File:Flag_of_Europe.svg



What does this all mean?

https://societyinforisk.org

Follow the evidence

What does this all mean?

https://societyinforisk.org

Follow the evidence

Data > Dogma

What does this all mean?

https://societyinforisk.org

Thank you!

Thank you!

Slides, Connect & Resources

Resources:
hacklore.org
cyentia.com
www.first.org/epss

Connect:
linkedin.com/in/jbenninghoff/

Website:
jbenninghoff.com

Scan the QR code for slides and more! Questions? jbenninghoff.com/qr